Department of Information Engineering Technology

UNEVOC Network Member

Advance Database Management System
Fall 2025 , BS(CS)

Dr. HUMA ISRAR

DEPARTMENT OF COMPUTING

NATIONAL SKILLS UNIVERSITY, ISLAMABAD, PAKISTAN

Lecture 7

Databases Security Outline

- Database Security
- Over view of Security protocols
- Access Control mechanism
- Purpose of Access control in DBMS
- Discretionary Access control (DAC)
- Mandatory Access control (MAC)
- Role based Access Control (RBAC)

Security

- Security refers to the protection of the database against unauthorized access, either intentional or accidental.
  - Access Control includes:
  - Identification
  - Authentication
  - Authorization
  - Audit
  - Views
  - Encryption

Access Control Mechanisms

- **Identification** is how a user tells a system who he or she is (for example, by using a username).

- **Authentication** is the process of verifying a user's claimed identity (for example, by comparing an entered password to the password stored on a system for a given username).

Access Control Mechanisms

- **Authorization** the granting of a right or privilege that enables a subject to have legitimate access to a system or a system's object.

- **Accountability** uses such system components as audit trails (records) and logs to associate a subject with its actions. The information recorded should be sufficient to map the subject to a controlling user. Audit trails and logs are important for detecting security violations.

Purpose of Access control

- Protection from improper access- only authorized users should be granted access to objects of DBMS. This control should be applied on smaller objects (record, attribute, value).

- Protection from inference - inference of confidential information from available data should be avoided. This regards mainly statistical DBMSs.

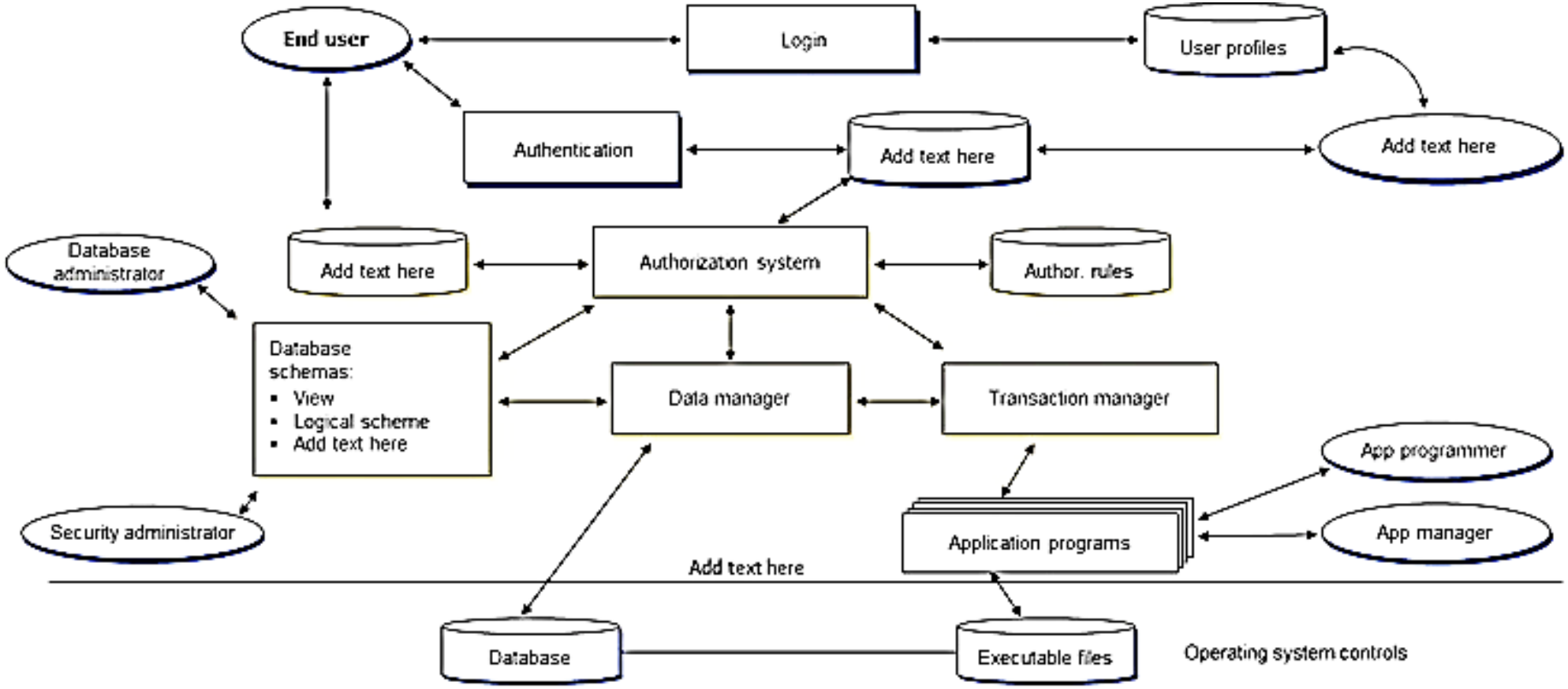
Purpose of Access control

- Database integrity - partially is ensured with system controls of DBMS (atomic transactions) and various back-up and recovery procedures and partially with security procedures.
- Operational data integrity - logical consistence of data during concurrent transactions (concurrency manager), serializability and isolation of transactions (locking techniques).
- Semantic data integrity - ensuring that attribute values are in allowed ranges. This is ensured with integrity constraints.

Purpose of Access control

- Accountability and auditing - there should be possibility to log all data accesses.
- User authentication - there should be unambiguous identification of each DBMS user. This is basis for all authorization mechanisms.
- Management and protection of sensitive data - access should be granted only to narrow round of users.
- Multilevel security - data may be classified according to their sensitivity. Access granting should then depend on that classification.

Access Control in DBMS



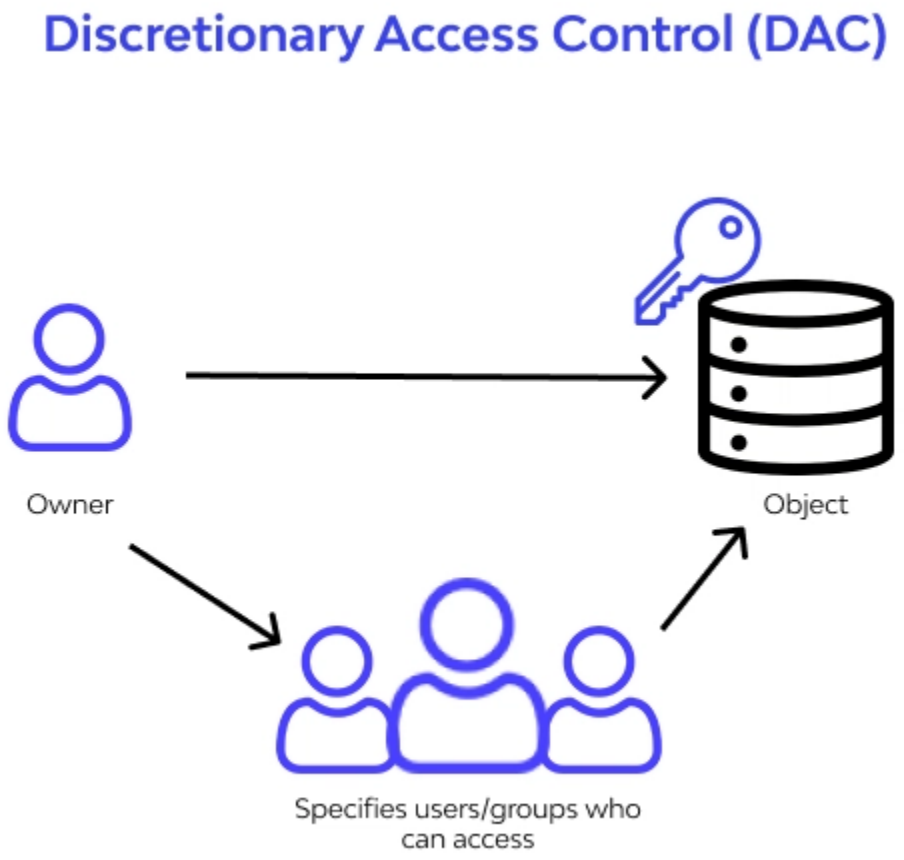
Access Control (AC)

- AC is a way to control the data that is addressable to a given user. Access control” is where security engineering meets computer science.
- Its function is to control which (active) subject have access to a which (passive) object with some specific access operation.
- Discretionary Access Control (DAC)
- Mandatory Access control (MAC)
- Role-based Access Control (RBAC)

Discretionary Access Control (DAC)

- DAC is an access policy determined by the owner of an object. The owner decides who is allowed to access the object and what privileges they have.
- It is based on the concept of access rights (privileges) and mechanisms for giving users such privileges.
- A privilege is an action that a user is permitted to carry out on a given table e.g., INSERT, SELECT, DELETE, UPDATE, REFERENCES etc.

Access Control in DBMS



DAC

- DAC controls access to data in a one-dimensional, binary way, meaning that access is granted or denied to the entire object.

- The controls are discretionary in the sense that a subject with a certain access permission is capable of passing that permission (perhaps indirectly) on to any other subject.

SQL Security Model

- SQL supports discretionary access control through the GRANT and REVOKE statements.

```
GRANT      {PrivilegeList | ALL PRIVILEGES}
ON         ObjectName
TO         {AuthorizationList | PUBLIC}
[WITH GRANT OPTION]
```

Privilege List

```
SELECT
DELETE
INSERT     [(columnName [,…])]
UPDATE     [(columnName [,…])]
REFERENCES [(columnName [,…])]
```

GRANT Statement

```
GRANT       ALL PRIVILEGES
ON          Student
TO          Teacher
WITH GRANT OPTION
```

```
GRANT       SELECT, UPDATE (student_name)
ON          Student
TO          Teacher, Acct_Manager
```

Example

GRANT SELECT ON Student TO Ahmad

GRANT SELECT ON Student_Degree TO Ahmad

WITH GRANT OPTION

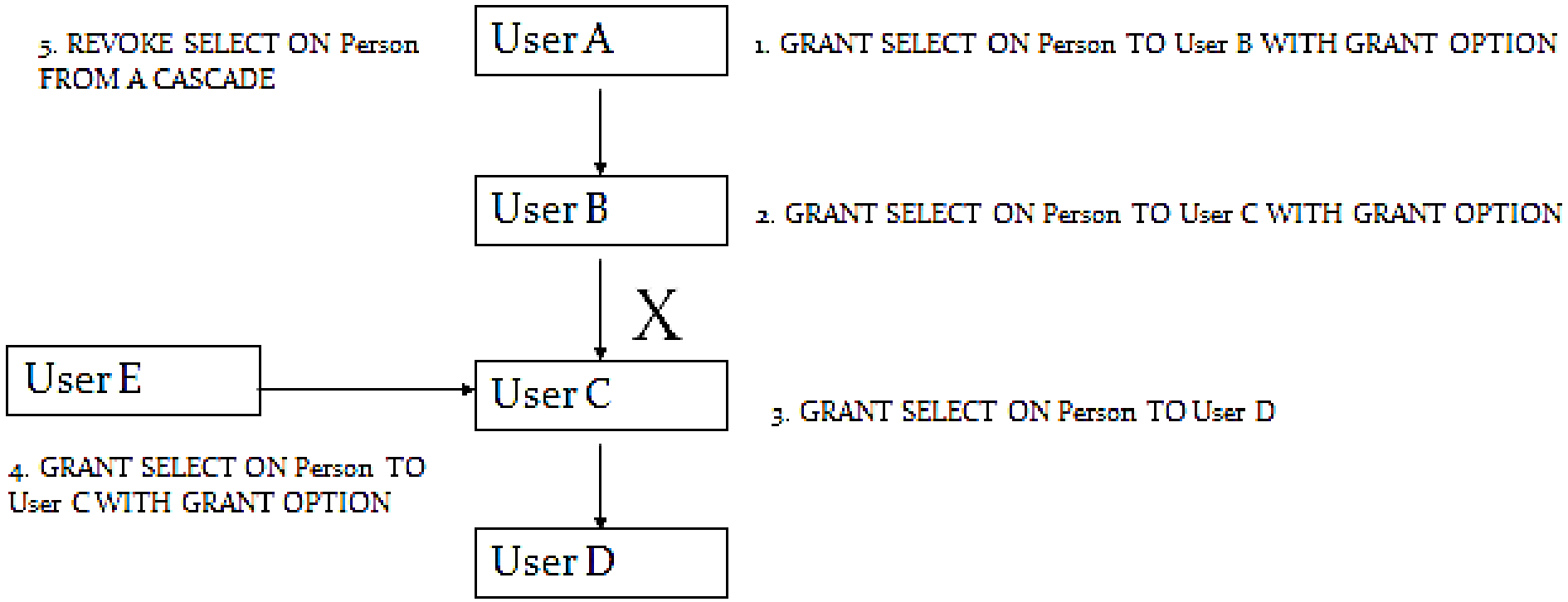
- Ahmad can create following view but cannot grant SELECT on the view to others

Revoke

```
REVOKE      [GRANT OPTION FOR]
            {PrivilegeList | ALL PRIVILEGES}
ON          ObjectName
FROM        {AurhorizationidList | PUBLIC}
            [RESTRICT | CASCADE]

REVOKE      SELECT
ON          Person
FROMAhmad
```

Revoke


5. REVOKE SELECT ON Person FROM A CASCADE
User A
1. GRANT SELECT ON Person TO User B WITH GRANT OPTION
User B
2. GRANT SELECT ON Person TO User C WITH GRANT OPTION
X
User E
User C
3. GRANT SELECT ON Person TO User D
4. GRANT SELECT ON Person TO User C WITH GRANT OPTION
User D

Discretionary control

- has some flaws, e.g., the Trojan horse problem:
- Tom creates A table XYZ and gives INSERT privileges to Jerry (who doesn't know about this).
- Tom modifies the code of an application program used by Jerry to additionally write some secret data to table XYZ.
- Now, Tom can see the secret info.
- The modification of the code is beyond the DBMSs control, but it can try and prevent the use of the database as a channel for secret information.

Mandatory Access Control (MAC)

- A means of restricting access to objects based on the sensitivity (as represented by a label) of the information contained in the objects and the formal authorization (i.e., clearance) of subjects to access information of such sensitivity.
- MAC is an access policy determined by the system, not the owner.
- MAC is used in multilevel systems that process highly sensitive data, such as classified government and military information. A multilevel system is a single computer system that handles multiple classification levels between subjects and objects.

Mandatory Access Control (MAC)

- Based on system-wide policies that cannot be changed by individual users
- Most commercial systems do not support mandatory access control. Versions of some DBMSs do support it
- used for specialized (e.g., military) applications.

MAC

- Objects (e.g., tables, views, tuples)
- Subjects (e.g., users, user programs)
- Security classes:
- Top secret (TS), secret (S), confidential (C), unclassified (U): TS > S> C > U
- Each object and subject is assigned a class.
- Subject S can read object O only if class(S) >= class(O) (Simple Security Property)
- Subject S can write object O only if class(S) <= class(O)
- (*-Property)

MAC

- Users with S and TS clearance will see both rows;
- a user with C will only see the 2nd row;
- a user with U will see no rows.
- A user with C tries to insert <101,Pasta,Blue,C>:
  - – Allowing insertion violates key constraint
  - – Disallowing insertion tells user that there is another
- object with key 101 that has a class > C!
  - – Problem resolved by treating class field as part of key.

ID	D-name	Color	Class
101	Salsa	Red	S
102	Pinto	Brown	C

MAC

- The mandatory access control rules are applied in addition to any discretionary controls that are in effect.
- SQL-92 standard does not include any support for mandatory access control.

Role-Based Access control

- In SQL-92, privileges are actually assigned to authorization ids, which can denote a single user or a group of users.
- In SQL:1999 (and in many current systems), privileges are assigned to roles.
- Roles can then be granted to users and to other roles.
- Reflects how real organizations work.
- Illustrates how standards often catch up with “defacto” standards embodied in popular systems.

Any Question ??